

1. Organisational Profile.....	2
1.1 Overview of the Organisation.....	2
1.2 Key Assets and Business Objectives.....	2
1.3 Legal, Regulatory, and Contractual Obligations.....	2
1.4 Risk Assessment:.....	3
2. Security Goals and Objectives.....	4
2.1 SMART Security Goals.....	4
2.2 Alignment with Organisational Objectives.....	5
3.Detailed Security Policies and Procedures:.....	5
3.1 Data Security Policy:.....	5
3.2 Incident Response Policy:.....	6
4.Countermeasures Implementation.....	7
4.1 Access Control and Data Encryption(First Countermeasure).....	8
4.1.1.Integration into the Organization:.....	8
4.1.2. Implemented Tools:.....	8
4.2. Regular and Secure Data Backups(seconde Countermeasure).....	8
4.2.1.Implemented Tools:.....	9
5. Security Awareness and Training Program.....	9
5.1 Key Security Topics to be Covered.....	9
5.2 Training Methods.....	10
6.References.....	11

1.Organisational Profile

1.1 Overview of the Organisation

Al Bawani is one of the major private construction and infrastructure entities in Saudi Arabia, created in 1991. It functions as a top-class contractor and has completed about 250 significant projects in or related to healthcare, education, defense, and infrastructure (Al Bawani, n.d.). Besides employing more than 12,000 people, the organization is managing important contracts worth over \$2.4 billion. As of late 2023, company revenue is expected to hit \$7.2 billion in 2027 as the increased demand for services matches the aims of Saudi Arabia's Vision 2030 (Zawya, 2023).

1.2 Key Assets and Business Objectives

Sensitive data and important documents play a big role in how Al Bawani works. Important information assets owned by the company are:

- 1- Architecture and structure blueprints
- 2- Contracts signed by government and private organizations
- 3- Project management includes using internal communication and documenting projects.
- 4- The data for employees and clients.
- 5- Financial database systems and purchasing tools

The company aims to deliver big projects on time and on budget, keep its operations stable, and contribute to the nation's major development plans. Al Bawani is an important part of improving infrastructure in the Kingdom and is closely involved in significant, government-related projects.

1.3 Legal, Regulatory, and Contractual Obligations

Al Bawani must comply with several cybersecurity standards due to the nature of its projects. These include:

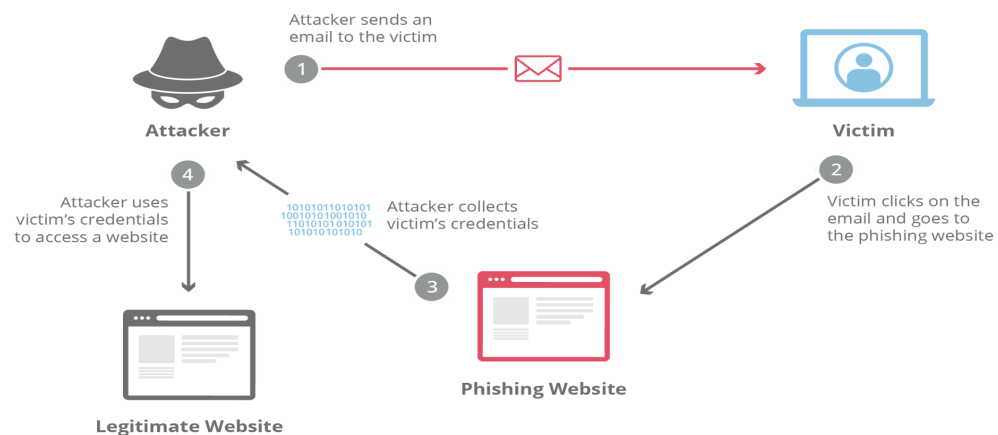
- National Cybersecurity Framework (ECC):
 - A. Issued by the National Cybersecurity Authority (NCA).
 - B. Mandatory for entities managing Saudi Arabia's critical infrastructure
 - C. Requires implementation of controls across systems handling government projects.

- Personal Data Protection Law (PDPL):
 - A. Enforced by the Saudi Data and Artificial Intelligence Authority (SDAIA).
 - B. Governs the collection, processing, and storage of personal data.
 - C. Ensures protection of employee, client, and stakeholder information.

- Government Contractual Obligations:
 - A. Strict data confidentiality
 - B. Prompt breach notification and incident response
 - C. Regular cybersecurity audits and compliance reporting

1.4 Risk Assessment:

Threat 1: Phishing Attacks:



Which exploits the vulnerability of low employee awareness and the absence of multi-factor authentication (MFA). Phishing emails encourage employees to hand over their credentials, which allows attackers to get into the company's systems. If MFA and training are not used, the threat becomes much greater. The potential impact includes data leaks, slower project development, and loss of money. It is considered as high Probability, noticed especially among big businesses.

Threat 2: Insider Threats

Arising from excessive system privileges and weak access control. If some employees or contractors are given excessive access, they might mistakenly or purposefully disclose important information. Its potential impact is disclosure of information and heavy sanctions from regulatory authorities. Insider threats are moderately likely because it is hard to catch and defend against in big companies

2. Security Goals and Objectives

2.1 SMART Security Goals

Goal 1: Cut down on cases of phishing attacks.

Concentrating on teaching staff to avoid phishing threats, and reducing the number of incidents by half. Good results can be achieved by using training and practice attacks. This goal directly addresses the weakness identified in the 2025 DragonForce incident, making it crucial to Al Bawani's security. This needs to be done within 12 months.

Goal 2: Implement role-based access control (RBAC)

Within six months, RBAC will be implemented by the company on every system to minimize insider threats. As a result, employees are restricted from accessing data that is not necessary for their position. There will be a gradual rollout with the existing IT staff, so that access is carefully managed and the chance of data leaks is limited.

Goal 3: encrypt all important and confidential data.

Al Bawani plans to have all its confidential data encrypted by the end of 2025, both as it is in transit and at rest. It is based on modern encryption and provides added protection against breaches as well as compliance with national laws on data privacy.

Goal 4: Quarterly, the organization should perform vulnerability assessments.

From the third quarter of 2025, the company aims to run security audits every 3 months. The checks will be carried out by internal or external experts to uncover and deal with any weaknesses in the system. Ongoing checks will strengthen security and lessen the chances of attacks.

2.2 Alignment with Organisational Objectives

1- Trust and Data Integrity: When encryption is applied and phishing is reduced, stakeholders are more confident.

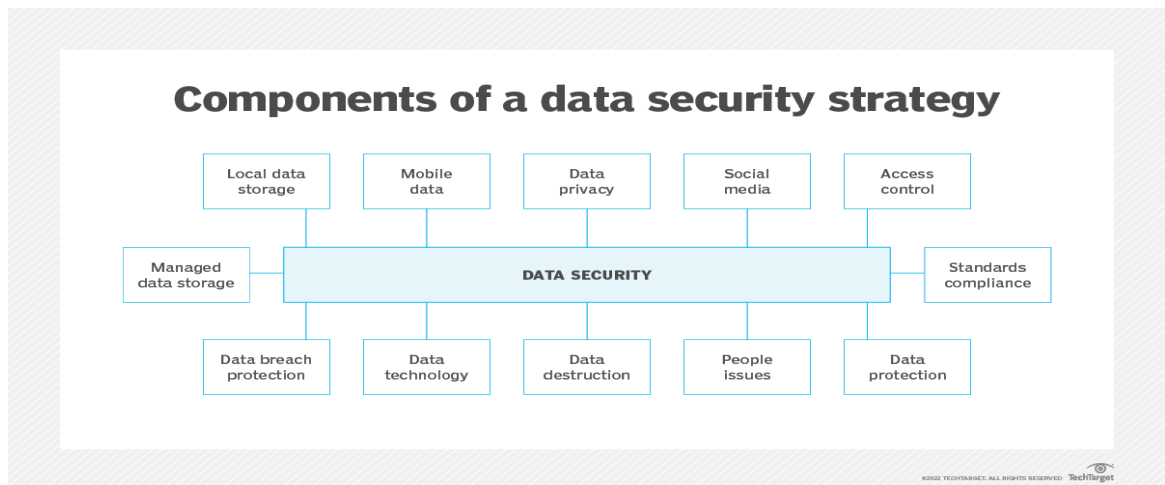
2- Project Continuity: Regular check-ups and safe controls are necessary for operational smoothness.

3- Regulatory Compliance: Maintaining compliance with ECC and PDPL standards saves the contract from penalties.

4- National Goals: Ensuring infrastructure is secure and fits into the transformation plan of Saudi Vision 2030.

3.Detailed Security Policies and Procedures:

3.1 Data Security Policy:



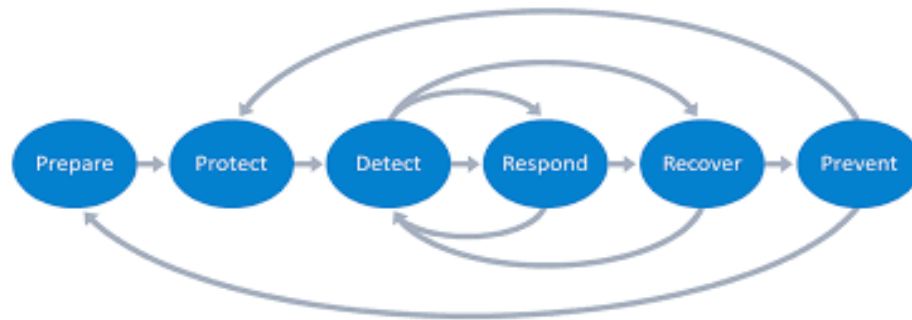
Objective:

To safeguard sensitive organizational data from unauthorized access, disclosure, alteration, or destruction, both in transit and at rest.

Data Security Policy Details:

- **Data Classification:** All data must be classified (e.g., Confidential, Internal, Public) and protected accordingly so data can be identified easily .
- **Storage Requirements:** Sensitive data must be encrypted using AES-256 encryption and stored in secure, access-controlled systems by using encryption technology that makes the data more secure .
- **Access Control:** Access to sensitive data is granted strictly on a need-to-know basis, following role-based access control (RBAC) principles and implementing proper access control policy .
- **Data Transmission:** Transmission of sensitive data must use secure protocols such as HTTPS, SFTP, or VPN.
- **Backup and Retention:** Critical data must be backed up daily and stored in offline and cloud-based encrypted environments with a minimum 30-day retention.

3.2 Incident Response Policy:



Objective:

To establish a structured approach for detecting, reporting, managing, and recovering from cybersecurity incidents, minimizing damage and restoring operations quickly.

Policy Details:

Any situation that could undermine the security of information assets bears the status of an incident. Rapid and proper handling of issues is important for reducing any possible negative outcomes.

As soon as an incident happens, report it via email, through a phone call, or using the ticket system to the IT Security Operations Center.

It is the job of a Computer Security Incident Response Team (CSIRT) to lead all the investigations, contain risks, and deal with the consequences of any event.

The incident response process follows a structured life cycle consisting of the following phases:

1. Detection and Analysis – Identifying and evaluating the scope and nature of the incident.
2. Containment – Isolating affected systems to prevent further damage.
3. Eradication – Removing the root cause and any related artifacts from the environment.
4. Recovery – Restoring systems and operations to normal while ensuring the threat is fully eliminated.
5. Post-Incident Review – Assessing the response, identifying lessons learned, and recommending improvements.

All actions, findings, and decisions throughout the process must be thoroughly documented in the official incident report log.

4.Countermeasures Implementation

Data Encryption, Access Control, and Secure Backups are all used as part of Al Bawani's main cybersecurity plan. They were actually meant to limit major risks and ensure the company was protected by choosing what was suitable for the situation .

4.1 Access Control and Data Encryption(First Countermeasure)

4.1.1.Integration into the Organization:

Encryption and creating roles with specific permissions will be used to guard something important like financial records and HR files.

Step	Action	Responsible	TimeLine
1	Identify sensitive data	IT Security team	Week 1-2
2	Enable full disk encryption(BitLocker/VeraCrypt)	IT admin	Week 2-3
3	Implement RBAC via microsoft active directory	IT +HR team	Week 4
4	Configure secure data transfer(TLS/SSL)	IT Security team	Week 4

T

4.1.2.Implemented Tools:

- 1.Choose BitLocker or VeraCrypt to secure your whole hard disk.
- 2.Microsoft Active Directory is in charge of AUTHORIZATION.

3.Encryption is provided through TLS/SSL certificates.

Encryption has to go together with access control to provide proper security. This is the reason that using both tools together is important.

The risks mentioned by this approach are internal access, data exposure, and unapproved viewing. Taking care of sensitive data and guaranteeing compliance to rules on data protection aids in keeping the company secure.

4.2. Regular and Secure Data Backups(second Countermeasure)



Integration into the Organization: To ensure business continuity, a hybrid backup approach will be used:

Step	Action	Responsible	TimeLine
1	Define backup scope and policies	System Manager	Week 1
2	Automate local backup using Acronis	Security Analysts	Week 2-3
3	Set up cloud backup on Azure	IT team	Week 4
4	Test restores and train staff	IT team	Week 5-6

4.2.1.Implemented Tools:

1: Acronis Cyber Backup for local encrypted backups.

2:Microsoft Azure uses cloud solutions to recover from any disaster.

The countermeasure makes use of safe cloud storage and automatic data backups to limit risks from ransomware, system failure, and losing important information. It keeps operations running by minimizing periods of system failure, lowering downtime expenses, quickly retrieving data, and increasing the system's dependability through multiple copies.

The company improves its defence by acting to prevent risks and being prepared for any possible incidents. Backups help operations won't be interrupted by an incident, while encryption defends the data.

5. Security Awareness and Training Program

The company's human firewall will be improved by Al Bawani introducing an ongoing program for training and awareness on security. This initiative looks to reduce security risks caused by people, increase following the law, and get every department to focus on security.

The reasons for running this Training Program

- 1) Inform your staff on the main rules of cybersecurity and the more detailed points.
- 2) See to it that staff members comprehend security policies set by the employer (for example, encryption and backups).
- 3) Act in a secure manner when using technology every day.
- 4) Lower cases of phishing, using social engineering tactics, or taking benefit of improper use of systems.

5.1 Key Security Topics to be Covered

Topic	Description
Phishing and Social Engineering	How to identify and report suspicious emails or messages.
Secure Use of Devices	Password hygiene, locking devices, avoiding public Wi-Fi.
Data Handling and Protection	Encrypting sensitive files, avoiding data leaks.
Backup and Recovery	Understanding backup importance and how restoration works.
Role-Based Access	Why and how employees should follow role-based access.

All employees, with additional role-based training for

- 1) IT Staff
- 2) HR & Admin
- 3) Project Managers

5.2 Training Methods

Method	Frequency	Tools
Online Modules	Quarterly	GoogleClassroom, Microsoft Teams,Zoom
Live Webinars	Bi-annually	Zoom/MS Teams
Posters & Infographics	Monthly	Office walls, emails
Simulated Phishing Tests	Monthly	PhishMe / GoPhish
Security Drills	Monthly	Led by IT Security Team

6. References

Al Bawani. (n.d.). *About Us*. Retrieved June 4, 2025, from <https://www.albawani.net/about-us/>

Zawya. (2023, November 21). *Al Bawani expects revenue to grow to \$7.2bln by 2027*. Retrieved from <https://www.zawya.com/en/markets/equities/albawani-expects-revenue-to-grow-to-72bln-by-2027-kpadmamu>

National Cybersecurity Authority. (2023). *Guide to Essential Cybersecurity Controls (ECC) Implementation*. Retrieved from <https://nca.gov.sa/en/regulatory-documents/guidelines-list/gecc/>

Resecurity. (2025, February). *DragonForce ransomware group is targeting Saudi Arabia: Al Bawani hit by cyberattack*. Retrieved from <https://www.resecurity.com/blog/article/dragonforce-ransomware-group-is-targeting-saudi-arabia>

Saudi Data and Artificial Intelligence Authority. (2021). *Personal Data Protection Law (PDPL)*. Retrieved from <https://sdaia.gov.sa>